

REGIONE DEL VENETO



AZIENDA
Z E R O



DXC.technology



Specifiche di integrazione
autenticazione APMS

Azienda Zero

CONSIP - LOTTO 4

Sistemi Gestionali Integrati per le Pubbliche Amministrazioni - ID

SIGEF 1607

CONTRATTO ESECUTIVO – LOTTO 4

Affidamento dei servizi in ambito dei sistemi informativi gestionali e sistemi di gestione dei procedimenti amministrativi in favore degli enti del Servizio Sanitario Nazionale

Specifiche di integrazione autenticazione APMS – Team di sviluppo

Identificativo: SGI-WP1-Specifiche di integrazione autenticazione APMS-Team di sviluppo-v1.4.docx

Data ultimo aggiornamento: 22/11/2024

Riservato

ATTENZIONE

REGIONE DEL VENETO



AZIENDA
Z E R O



DXC.technology



Specifiche di integrazione
autenticazione APMS

Ogni copia cartacea del presente documento si ritiene non controllata. È responsabilità di chi utilizza copie non controllate verificarne il livello di aggiornamento.

   	Specifiche di integrazione autenticazione APMS
---	---

Data	Nominativo
Redatto	
15/11/2021	DXC

Validato	

Approvato	

Registro delle Revisioni

Rev.	Data	Descrizione	Autore
1.0	15/11/2021	Prima emissione	DXC
1.1	16/03/2022	Seconda emissione	DXC
1.2	26/09/2023	Descrizione flusso di autenticazione MFA	DXC
1.3	19/04/2024	Introduzione dell'autenticazione M2M	DXC
1.4	22/11/2024	Logout multi-client	DXC



1 INTRODUZIONE	6
1.1 Scopo del documento	6
2 RIFERIMENTI	7
2.1 Documenti applicabili	7
2.2 Documenti di riferimento	7
2.3 Notazioni utilizzate	7
2.4 Definizioni ed acronimi	7
3 SISTEMA D'AUTENTICAZIONE	8
3.1 Utenti Federati	8
3.2 Utenti Locali	9
3.2.1 Flussi di gestione	10
3.3 Profilo Applicativo	11
3.4 Cognito User Pool	11
3.4.1 Attributi	11
3.4.2 Client di App	12
3.5 Token Autorizzativo (ID_Token)	12
3.6 Architettura applicativa	13
3.6.1 Logon	14
4 INTEGRAZIONE AUTENTICAZIONE APMS	15
4.1 Informazioni generali d'impostazione dello User Pool di Amazon Cognito	16
4.2 Informazioni delle impostazioni del client dell'applicazione.	18
4.2.1 Personalizzazione dell'aspetto delle pagine di autenticazione	19
4.3 Informazioni restituite dal team di operation al team di sviluppo	19
5 ESEMPIO DI INTEGRAZIONE	21
5.1 Flusso di autenticazione	21
5.2 Rinnovo dell'ID_Token	23
6 INTEGRAZIONE DI MULTI FACTOR AUTHENTICATION (MFA)	23
7 INTEGRAZIONE AUTENTICAZIONE MACHINE TO MACHINE (M2M)	25
7.1 Scenario di autenticazione M2M	25
7.2 Flusso di autenticazione	25

	Specifiche di integrazione autenticazione APMS
---	---

1 INTRODUZIONE

APMS (*Application Profile Management System*) è il Sistema di cui si è dotata Azienda Zero per la gestione dell'autenticazione e profilazione degli utenti per le architetture applicative su cloud AWS del tipo descritto nel documento *Reference Architecture*. APMS è un sistema che integra i sistemi di autenticazione già esistenti in Azienda Zero, gli Identity Provider installati nei vari enti, con il sistema di autenticazione AWS, Cognito, ed il database di profilazione.

Per una descrizione dettagliata sui meccanismi di autenticazione implementati da APMS si faccia riferimento al seguente capitolo 3 del presente documento.

1.1 Scopo del documento

Questo manuale è rivolto ai team di sviluppo (la parte Dev di DevOps) e descrive le operazioni che questi devono eseguire per integrare l'autenticazione APMS nella loro applicazione. Per l'integrazione della profilazione APMS si rimanda al relativo manuale.

	Specifiche di integrazione autenticazione APMS
---	---

2 RIFERIMENTI

2.1 Documenti applicabili

Codice	Titolo

2.2 Documenti di riferimento

Codice	Titolo
SGI-WP1-Reference_Architecture	Reference Architecture
https://aws.amazon.com/it/cognito/	Documentazione Amazon Cognito

2.3 Notazioni utilizzate

Notazione	Descrizione

2.4 Definizioni ed acronimi

Definizione	Descrizione
Utenti Locali	Utenti censiti direttamente nello user pool di Amazon Cognito dedicato all'applicazione
Utenti Federati	Utenti appartenenti alla federazione IAP AziendaZero
MFA	Autenticazione a più fattori (Multi-Factor Authentication)

	Specifiche di integrazione autenticazione APMS
---	---

3 SISTEMA D'AUTENTICAZIONE

Ciascuna applicazione accede ai propri servizi di *back end* utilizzando un Token Autorizzativo JWT ottenuto da Cognito. Per ottenere il Token Autorizzativo l'applicazione deve avviare l'*Authorization Code Flow* del protocollo OIDC (Open ID Connect) esposto da Cognito. È durante questa fase che scatta il flusso di autenticazione.

Il flusso di autenticazione, così come la sua implementazione, cambia in base alla tipologia degli utenti che devono poter accedere al sistema. Per una più chiara esposizione, gli utenti sono suddivisi in:

- Utenti Federati: sono gli utenti definiti sugli Identity Provider che definiscono lo IAP.
- Utenti Locali: sono gli utenti definiti direttamente su uno User Pool di Cognito.

Un'applicazione potrebbe essere accessibile solo dagli Utenti Federati, solo dagli Utenti Locali o da entrambe le tipologie di utente. Resta inteso che per gli Utenti Locali non è possibile accedere ai servizi infrastrutturali (Anagrafe 2, FSE, ecc.) utilizzando la propria identità ma devono avvalersi di speciali utenze applicative.

3.1 Utenti Federati

L'utente che desidera autenticarsi viene fatto rimbalzare dall'applicazione verso lo User Pool di Cognito. Se sullo User Pool non è attivata anche la possibilità di autenticarsi come Utente Locale allora il sistema direziona automaticamente l'utente verso la scelta dello IAP sul quale eseguire il login, in caso contrario, l'utente deve scegliere esplicitamente di autenticarsi in qualità di utente federato. Una volta autenticato, l'utente è riportato sulla home page dell'applicazione.

La realizzazione di una nuova applicazione comporta l'implementazione del livello applicativo di autenticazione e della definizione dello User Pool (cfr. § 3.4) specifico per l'applicazione.

	Specifiche di integrazione autenticazione APMS
---	---

L'identificativo che individua univocamente l'Utente Federato è il suo Codice Fiscale. Il Codice Fiscale è propagato dall'*Identity Provider* su cui l'utente si è autenticato fino al livello di Cognito tramite un apposito attributo SAML. L'applicazione può recuperare il Codice Fiscale dagli attributi del Token Autorizzativo.

Durante la fase di autenticazione il sistema APMS (Application Profile Management System) provvede ad associare all'utente le informazioni del suo Profilo Applicativo. Il profilo applicativo non dipende solo dall'utente e dall'applicazione specifica a cui sta accedendo, ma anche dall'Identity Provider dal quale l'utente si è autenticato (la chiave del profilo è una chiave composta dal Codice Fiscale, dal Codice Applicazione e dal Codice Struttura). L'applicazione può recuperare le informazioni del Profilo Applicativo dagli attributi del Token Autorizzativo.

3.2 Utenti Locali

Per gli Utenti Locali il meccanismo di autenticazione è quello semplificato di Figura 1.

L'utente che desidera autenticarsi viene fatto rimbalzare dall'applicazione verso lo User Pool di Cognito dove si autentica.

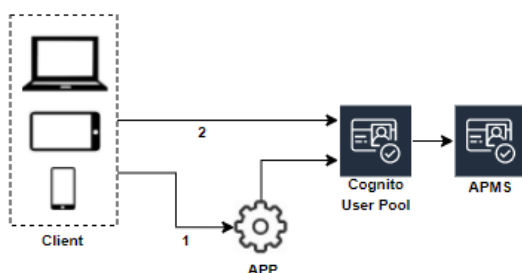


Figura 1 - Autenticazione Utente Locale

Il protocollo di autenticazione utilizzato tra l'applicazione e Cognito è OIDC.

La realizzazione di una nuova applicazione comporta l'implementazione del livello applicativo di autenticazione e la definizione di uno User Pool (cfr. § 3.4) specifico per l'applicazione.

	Specifiche di integrazione autenticazione APMS
---	---

L'identificativo che individua univocamente l'Utente Locale è il suo Codice Fiscale. L'applicazione può recuperare il Codice Fiscale dagli attributi del Token Autorizzativo.

Durante la fase di autenticazione il sistema APMS (*Application Profile Management System*) provvede ad associare all'utente le informazioni del suo profilo applicativo. L'applicazione può recuperare le informazioni del Profilo Applicativo dagli attributi del Token Autorizzativo.

3.2.1 *Flussi di gestione*

Per gli Utenti Locali sono previsti i seguenti flussi di gestione:

- Registrazione – l'utente di un'applicazione è definito sul sistema APMS dove l'amministratore provvede ad inserire le informazioni di: nome; cognome; codice fiscale; e-mail; gruppi ed attributi. APMS autonomamente censisce l'utente sullo User Pool di Cognito dedicato all'applicazione. Lo userid utilizzato per definire l'utente sullo User Pool è l'e-mail.
- Primo accesso – l'utente riceve una e-mail che lo invita a connettersi al sistema per completare la registrazione. Durante il completamento della registrazione l'utente definisce la propria password. Il flusso è gestito completamente da Cognito.
- Password dimenticata (reset password) – su sua richiesta, l'utente riceve una e-mail con le istruzioni per ridefinire la propria password. Il flusso è gestito completamente da Cognito.
- Scadenza password – l'applicazione legge dal Token Autorizzativo la data di scadenza della password (`apms:scadenza_pwd`) e, nel caso, inibisce l'operatività invitando l'utente a modificare la password d'accesso. Il sistema APMS espone un'API di supporto al cambio password. La gestione è in parte in carico ad APMS ed in parte delegata all'applicazione.

Quando richiesto esplicitamente dai requisiti è necessario predisporre il sistema per l'accesso con il MFA (*Multi Factor Authentication*).

	Specifiche di integrazione autenticazione APMS
---	---

3.3 Profilo Applicativo

L'implementazione di una nuova applicazione, generalmente, comporta la necessità di definire i Profili Applicativi dei Gruppi (tipologie) di utenti che vi possono accedere (es. Amministratore, Lettore, ecc.) e di una serie di attributi che caratterizzano nel dettaglio l'utente. In sintesi, il Profilo Applicativo è costituito da un insieme di informazioni associate all'utente che l'applicazione utilizza per realizzare nel dettaglio il RBAC (*Role Based Access Control*). Il Profilo Applicativo è gestito centralmente nel sistema APMS (*Application Profile Management System*) e per una esposizione più dettagliata si rimanda alla documentazione di riferimento.

Al termine del flusso di autenticazione il Token Autorizzativo conterrà l'attributo `apms:gruppi` contenente i gruppi ai quali appartiene l'utente separati da ",". Nel Token Autorizzativo saranno poi presenti gli attributi associati all'utente sul sistema APMS i cui nomi hanno il formato `apms:[nome attributo]` dove `[nome attributo]` è il nome dell'attributo definito in APMS.

Il profilo applicativo è valido sia per gli Utenti Federati sia per gli Utenti Locali.

3.4 Cognito User Pool

Uno User Pool opportunamente configurato presenterà le sezioni riportate nei paragrafi che seguono.

3.4.1 Attributi

Attributi standard:

- `family name`
- `given name`

a cui si aggiungono i seguenti attributi personalizzati (i nomi devono essere esattamente quelli riportati)

- `codice_fiscale`

- codice_struttura
- userid_idp
- issuer_idp
- endpoint_idp

questi ultimi hanno impostato il flag *Mutable*.

3.4.2 Client di App

Un nuovo Client di App avrà definiti:

- ID del client
- Secret del client
- ALLOW_REFRESH_TOKEN_AUTH
- Autorizzazione in lettura e scrittura degli attributi personalizzati
- Identity Provider desiderati (Federazione SAML e/o Cognito)
- URL di accesso e disconnessione. Sono le URL di *login* e *logout* esposte dall'applicazione
- Authorization Code grant con OpenID e Profile

3.5 Token Autorizzativo (*ID_Token*)

Nel riquadro di seguito un esempio reale di Token Autorizzativo per un Utente Federato.

```
{
  "at_hash": "pqU1OyLXpa2L_pi9fM8IQQ",
  "custom:issuer_idp": "https://webauth-test.azero.veneto.it/idp/metadata",
  "sub": "a1b0a30b-d96a-4166-abc2-bfb9d170a2e8",
  "cognito:groups": [
    "eu-central-1_HFKeJNvjn_AZeroShibProxy"
  ],
  "email_verified": false,
  "custom:codice_struttura": "050511",
  "custom:codice_fiscale": "PPNNNN00M00A111X",
  "iss": "https://cognito-idp.eu-central-1.amazonaws.com/eu-central-1_HFK",
  "cognito:username": "azeroshibproxy_ve3dq6apfwmxae5oikp5bc72rs233keq",
  "given_name": "Test nome",
  "custom:userid_idp": "Test user id idp",
  "aud": "17uf34ptjs4229a974b0pamqog",
  "identities": [
    {
```

```
{
  "userId": "VE3DQ6APFWMXAE5OIKP5BC72RS233KEQ",
  "providerName": "AZeroShibProxy",
  "providerType": "SAML",
  "issuer": "https://apms-svi.azero.veneto.it/idp/shibboleth",
  "primary": "true",
  "dateCreated": "1600771241466"
}
],
"token_use": "id",
"auth_time": 1601540467,
"apms:gruppi": "op_SIRMI,am_SIRMI",
"apms:ufficio": "0010",
"apms:provincia": "VE",
"exp": 1601544068,
"custom:endpoint_idp": "https://trustapp-test.azero.veneto.it/ws",
"iat": 1601540468,
"family_name": "Test cognome"
}
```

Nel riquadro di seguito un esempio reale di Token Autorizzativo per un Utente Locale.

```
{
  "at_hash": "oImUlUZ8FrDTfiQP9Ka9hg",
  "sub": "9de14401-ea0d-43c9-bab2-df5a593c5470",
  "email_verified": true,
  "custom:codice_struttura": "local",
  "custom:codice_fiscale": "PPPNNN00M00A111X",
  "iss": "https://cognito-idp.eu-central-1.amazonaws.com/eu-central-1_f8",
  "cognito:username": "testsirca",
  "given_name": "Test",
  "aud": "h1vb7mnn3nbbkmo6e8hg95894",
  "event_id": "680b05c3-8754-4030-a028-d5a37c65e7ac",
  "token_use": "id",
  "auth_time": 1601538698,
  "apms:gruppi": "mca",
  "apms:sede": "0010",
  "apms:scadenza_pwd": "2020-10-06",
  "exp": 1601542301,
  "iat": 1601538701,
  "family_name": "Sirca"
}
```

3.6 Architettura applicativa

Il flusso di autenticazione segue l'authorization flow di OIDC (*Open ID Connect*) con l'uso del PKCE (*Proof Key for Code Exchange*). Nel caso sia richiesto, il meccanismo di autenticazione deve prevedere l'utilizzo del *refresh token* per evitare che ogni ora, durata dell'*ID_Token*, l'utente sia costretto ad autenticarsi di nuovo. Sia l'*ID_Token* sia il *refresh token* devono

	Specifiche di integrazione autenticazione APMS
---	---

essere gestiti in modo da evitare vulnerabilità della sicurezza per l'applicazione sia a fronte di attacchi *Cross Site Scripting* (XSS) sia di *Cross Site Request Forgery* (CSRF).

In caso di *front end* di tipo SPA è possibile utilizzare anche delle componenti di *back end* che partecipino al processo di autenticazione (ad es. il BFF) in modo da abilitare l'utilizzo dei *cookie* per la conservazione delle informazioni critiche per la sicurezza.

3.6.1 Logon

Il *sequence* di *log on* si differenzia in base alla tipologia di utente che accede all'applicazione. Nel caso di Utente Federato il *sequence* è il seguente:

- 1- L'utente non autenticato accede all'APP e quest'ultima avvia l'*authorization flow* di OIDC con PKCE (cfr. letteratura di riferimento).
- 2- Il flusso di OIDC gestito da Cognito presenta all'utente la pagina di *login* di Cognito.
- 3- L'utente sceglie di autenticarsi tramite federazione IAP.
- 4- Cognito presenta all'utente la pagina su cui scegliere l'IdP federato col quale autenticarsi.
- 5- L'utente è rimandato all'IdP scelto per autenticarsi e quest'ultimo gli presenta la pagina di *login*.
- 6- L'utente inserisce le credenziali sull'IdP scelto e, in caso di autenticazione valida, è rimandato verso Cognito (passaggi automatici in forma di *redirect*).
- 7- Cognito chiama il sistema APMS per ottenere le informazioni del profilo utente e quindi confeziona l'*ID_Token* da restituire all'APP.
- 8- L'APP rimanda l'utente alla home page richiesta all'accesso del punto 1.

Nel caso di Utente Locale il *sequence* è il seguente:

- 1- L'utente non autenticato accede all'APP e quest'ultima avvia l'*authorization flow* di OIDC con PKCE (cfr. letteratura di riferimento).
- 2- Il flusso di OIDC gestito da Cognito presenta all'utente la pagina di *login* di Cognito.

- 3- L'utente sceglie di autenticarsi tramite user e password. In caso di autenticazione valida, Cognito chiama il sistema APMS per ottenere le informazioni del profilo utente e quindi confeziona l'*ID_Token* da restituire all'APP.
- 4- L'APP rimanda l'utente alla home page richiesta all'accesso del punto 1.

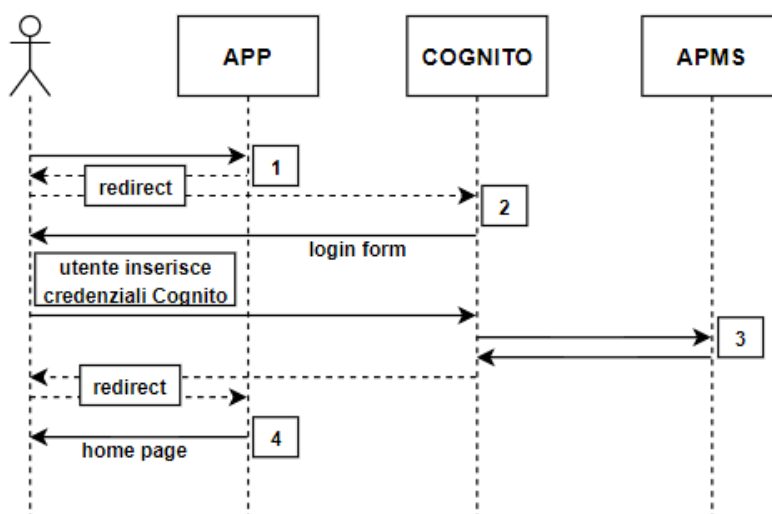


Figura 2 - Sequence di Logon Cognito

4 INTEGRAZIONE AUTENTICAZIONE APMS

L'integrazione dell'applicazione col sistema APMS è realizzata con il coinvolgimento sia del team di sviluppo, che si occupa della implementazione dell'applicazione, sia del team di operation, che si occupa della predisposizione degli ambienti di sviluppo, test e produzione dove l'applicazione verrà installata.

In questo manuale sono elencate le informazioni che il team di sviluppo deve fornire al team di operation per ottenere che l'integrazione con APMS soddisfi i requisiti di autenticazione dell'applicazione. Per la parte di progettazione applicativa dell'integrazione con APMS si rimanda al documento *Reference Architecture*.

	Specifiche di integrazione autenticazione APMS
---	---

Il manuale è rivolto solo al team di sviluppo mentre il team di operation deve fare riferimento ad un altro manuale preparato appositamente per esso.

Le informazioni che il team di sviluppo deve fornire al team di operation sono divise in due categorie descritte nei paragrafi successivi. In questi paragrafi sono elencate le informazioni necessarie ad implementare l'integrazione del sistema di autenticazione. Qualora ci sia bisogno, per esigenze specifiche, di modificare altri parametri di Amazon Cognito, è necessario condividere l'esigenza col team di operation per verificarne la fattibilità e concordare con esso le modalità di scambio delle informazioni di dettaglio.

4.1 Informazioni generali d'impostazione dello User Pool di Amazon Cognito

Ogni applicazione che necessita di attivare i meccanismi di autenticazione di Amazon Cognito deve essere associata ad uno User Pool (per i dettagli sullo User Pool si faccia riferimento alla documentazione online di Cognito). Le informazioni che il team di sviluppo deve fornire al team di operation per la creazione dello User Pool sono le seguenti.

- **Codice Applicazione:** è un codice alfanumerico che identifica univocamente l'applicazione nell'ambito APMS. Deve essere concordato con Azienda Zero
- **Testi messaggi flussi gestione utente** (registrazione, rinnovo password, ecc.): sono informazioni che vanno fornite solo se è stato richiesto, per almeno un client dell'app (vedi paragrafo successivo), l'accesso per gli Utenti Locali. Poiché Amazon Cognito prevede la possibilità di definire testi specifici per messaggi e-mail destinati agli utenti in alcuni frangenti del processo di autenticazione (ad esempio quello dell'e-mail di invito o quello per l'avvenuto reset della password) il team di sviluppo deve fornire al team di operation i testi di tali messaggi che saranno gli stessi per tutti i client delle applicazioni agganciate allo User Pool. Maggiori informazioni a riguardo possono trovarsi sulla documentazione specifica di Cognito. Più in generale, per tutte le possibili configurazioni e personalizzazioni dello user pool Amazon Cognito dell'applicazione si rinvia alla documentazione di Amazon Cognito disponibile on-line.

- **MFA:** è un'informazione che deve essere fornita solo se è stato richiesto, per almeno un client dell'app (vedi paragrafo successivo), l'accesso per gli Utenti Locali. Il valore da fornire al team di operation è sì o no a seconda che l'applicazione prevede il *Multi Factor Authentication*. Per ulteriori informazioni su come gestire il MFA dal punto di vista applicativo si faccia riferimento al manuale APMS di profilazione
- **URL log in:** quando si esegue il log out (vedere le specifiche tecniche di Cognito per il flusso OIDC), APMS propone una pagina di "avvenuta disconnessione" dove è presente un link che consente all'utente di rieseguire il log in. La URL di log in è l'indirizzo a cui deve puntare questo link e deve essere fornito dal team di sviluppo al team di operation
- **Dati utente amministratore:** è un'informazione che deve essere fornita solo se è stato richiesto l'accesso per gli Utenti Locali per almeno uno dei client dell'app (vedi paragrafo successivo). È necessario fornire al team di operation codice fiscale e indirizzo e-mail dell'utente amministratore

Nella tabella sottostante c'è il riepilogo delle informazioni da fornire al team di operation.

Parametro	Descrizione	Valore
Codice Applicazione	Codice alfanumerico che identifica univocamente l'applicazione nell'ambito APMS	Codice alfanumerico condiviso con Azienda Zero. Non può contenere caratteri speciali. Solo lettere e numeri.
Testi messaggi	Testi dei messaggi del flusso di gestione utente (Mail di registrazione, rinnovo password, ecc.)	Testi e oggetti dei messaggi email (usare documentazione di Amazon Cognito per una descrizione più dettagliata)
MFA	Attivazione MFA	si/no
URL log in	URL log in applicazione	URL
Dati utente amministratore	Primo utente per poter accedere al client	Codice Fiscale; Email

	Specifiche di integrazione autenticazione APMS
---	---

4.2 Informazioni delle impostazioni del client dell'applicazione.

Un'applicazione potrebbe, in alcuni casi, avere più client (es. front end desktop per le operazioni amministrative e front end mobile per l'operatività del personale che opera a domicilio). Per ciascun client associato all'applicazione è necessario fornire al team di operation le informazioni seguenti.

- **Nome client:** nome del client
- **Utenti Locali:** comunicare sì o no a seconda che il client prevede l'autenticazione degli Utenti Locali (per la definizione di Utenti Locali si faccia riferimento alla *Reference Architecture*)
- **Utenti Federati:** comunicare sì o no a seconda che il client prevede l'autenticazione degli Utenti Federati (per la definizione di Utenti Federati si faccia riferimento alla *Reference Architecture*)
- **URL callback:** l'autenticazione è realizzata con protocollo OIDC (si faccia riferimento alla documentazione on line), la URL da fornire al team di operation è la URL di callback dell'Authorization code flow e cioè la URL sulla quale il client deve essere richiamato da Amazon Cognito una volta staccato l'Authorization code
- **URL disconnessione:** è la URL su cui il client deve essere richiamato da Amazon Cognito al termine del flusso di log out
- **Gestione degli Utenti Locali:** è un'informazione che deve essere fornita solo se è stato richiesto l'accesso per gli Utenti Locali. Comunicare sì o no a seconda che il client gestisce direttamente gli Utenti Locali (creazione, modifica, cancellazione, etc. Per approfondimenti si faccia riferimento al manuale APMS di profilazione)

Nella tabella sottostante c'è il riepilogo delle informazioni da fornire, per ciascun client, al team di operation.

Parametro	Descrizione	Valore
Nome client	Nome del client	Nome del client. Non può contenere caratteri speciali. Solo lettere e numeri.

	Specifiche di integrazione autenticazione APMS
---	---

Utenti Locali	Il client autentica Utenti Locali	si/no
Utenti Federati	Il client autentica Utenti Federati	si/no
URL di callback	Callback dell'Authorization code flow	URL
URL disconnessione	URL su cui il client deve essere richiamato da Amazon Cognito al termine del flusso di log out	URL
Gestione Utenti Locali	Il client gestisce Utenti Locali	si/no

In caso di presenza di più client applicativi, al fine di specificare al sistema APMS verso quale client applicativo reindirizzare l'utente al completamento dell'operazione di logout (link "Clicca qui per riautenticarti"), è possibile aggiornare il valore del cookie `apms_{id_user_pool}` impostandolo con l'id del client applicativo desiderato. Nel caso in cui il cookie non venga modificato (e permanga dunque il valore `default`) all'utente verrà proposto il primo client censito per il pool di utenti.

4.2.1 Personalizzazione dell'aspetto delle pagine di autenticazione

Amazon Cognito consente di configurare e personalizzare alcune caratteristiche dell'aspetto e dello stile grafico delle pagine mostrate dal sistema durante le fasi del processo di autenticazione del client. Solo a titolo di esempio si citano la possibilità di mostrare un'immagine (banner) al di sopra dei contenuti specifici della pagina e quella di modificare dimensione dei font e colori di alcuni dei testi o degli elementi mostrati. Per una panoramica completa delle possibili configurazioni si veda la documentazione di Amazon Cognito. Tutte le personalizzazioni che si desidera applicare dovranno essere comunicate al team di operation.

4.3 Informazioni restituite dal team di operation al team di sviluppo

Una volta che il team di operation avrà eseguito le attività di creazione ed impostazione dello User Pool e di tutti i client di app restituirà al team di sviluppo le seguenti informazioni necessarie al completamento dell'integrazione.

	Specifiche di integrazione autenticazione APMS
---	---

- **Auth URL:** URL per l'avvio dell'Authorization code flow e per il log out (è la URL del dominio dello User Pool)

E, per ciascun client di app:

- **Client ID:** identificativo univoco del client
- **Client Secret:** secret del client

Per ulteriori approfondimenti si faccia riferimento alla documentazione online di OIDC per Amazon Cognito.

	Specifiche di integrazione autenticazione APMS
---	---

5 ESEMPIO DI INTEGRAZIONE

5.1 Flusso di autenticazione

Il *sequence* di *log on* utilizzato nell'esempio implementa quanto detto al § 3.6 ed è descritto nei passi seguenti:

- 1- SPA, per un utilizzatore non autenticato:
 - a. Genera il *code verifier* – è una stringa casuale composta dai caratteri A-Z, a-z, 0-9, e dai caratteri di punteggiatura - . _ ~ (trattino, punto, sottolineato, e tilde), di lunghezza compresa tra 43 e 128 caratteri. Il *code verifier* è conservato nel *Local Storage*.
 - b. Genera un codice casuale, *state*, conservato nel *Local Storage*.
 - c. Dal *code verifier*, ricava il *code challenge* come *hash* SHA256 del *code verifier*.
 - d. Esegue una *client-side Redirection* verso la *url* di *log on* di ATHN passando in *querystring* il *code challenge* e lo *state*.
- 2- ATHN avvia l'*Authorization code flow* di OIDC utilizzando *code challenge* e lo *state* tramite reindirizzamento all'apposito *endpoint* di Cognito. In caso di errori o dati di attivazione mancanti interrompe il processo di autenticazione ed esegue *redirect* alla pagina di errore della SPA.
- 3- COGNITO permette all'utente di autenticarsi. Al termine della procedura di autenticazione COGNITO reindirizza l'utente *sull'endpoint login-callback* di ATHN fornendo l'*authorization code* per la richiesta dei *token*.
- 4- ATHN
 - a. In caso di errori restituiti da COGNITO interrompe il processo di autenticazione ed esegue *redirect* alla pagina di errore della SPA.
 - b. Esegue una *client-side Redirection* alla *url* di *login-callback* della SPA. Passando in *querystring* l'*authorization code* e lo *state* ricevuti dalla *redirect* di COGNITO.
- 5- SPA



- a. Verifica che lo *state* inviato in *querystring* coincide con quello conservato nel *Local Storage*. In caso di verifica fallita interrompe il processo di autenticazione.
- b. esegue una chiamata HTTP ad ATHN per ottenere la Sessione Utente passando in input il *code verifier* prelevato dal *Local Storage* e l'*authorization code* ricevuto in *querystring*.

6- ATHN

- a. Esegue la chiamata di OAuth flow su COGNITO per ottenere *ID_Token* e *Refresh Token* passando in input il *code verifier* e l'*authorization code* ricevuti in input. In caso di errori restituisce a sua volta un errore che la SPA deve gestire per interrompere il processo di autenticazione.
- b. Coi dati ricevuti da COGNITO genera un *cookie* per il dominio comune tra SPA ed ATHN con nome *nome_app_ATHN*, di tipo *HttpOnly, SameSite, Secure*, coi seguenti dati:
 - i. Coda *Refresh Token* = ultimi 16 caratteri del *Refresh Token* ottenuto da COGNITO
 - ii. *Endpoint_idp* ricavato dall'*ID_Token* (*custom:endpoint_idp*)
 - iii. *Userid_idp* ricavato dall'*ID_Token* (*custom:userid_idp*)

crittati con una chiave segreta gestita nell'ambiente di deploy di ATHN.

- c. Restituisce alla SPA l'oggetto Sessione Utente contenente le seguenti informazioni:
 - i. Session ID = nuovo GUID generato ad hoc;
 - ii. *ID_Token*
 - iii. Testa *Refresh Token* = *Refresh Token* privato degli ultimi 16 caratteri e crittato

Al termine del flusso di autenticazione la SPA ha a disposizione l'*ID_Token* per accedere ai servizi di *back end*. Ritornando a quanto accennato nel punto 1, un utente risulta autenticato

	Specifiche di integrazione autenticazione APMS
---	---

quando per esso è definita una Sessione Utente. L'oggetto Sessione Utente è gestito in modo sicuro ed è mantenuto solo nella memoria di *runtime* di esecuzione di *javascript* sul *browser*. Si è evitato di utilizzare qualunque tipo di archiviazione locale del *browser* (*Local Storage*, *Session Storage*).

5.2 Rinnovo dell'*ID_Token*

Per il rinnovo dell'*ID_Token* la SPA chiama ATHN passando in *input* l'oggetto Sessione Utente. ATHN ricostruisce il *Refresh Token* a partire dalle informazioni passate in *input* e dal *cookie nome_app_ATHN* e chiama COGNITO per ottenere i nuovi *token*. Se il rinnovo è andato a buon fine restituisce alla SPA Sessione Utente e *cookie* aggiornati.

6 INTEGRAZIONE DI MULTI FACTOR AUTHENTICATION (MFA)

Il sistema APMS mette a disposizione la possibilità di far precedere il flusso di autenticazione e generazione dell'*ID_Token* da un'autenticazione a due fattori tramite one time password (OTP) gestita dal sistema stesso. L'utente riceverà via e-mail una OTP da inserire tramite un'apposita interfaccia predisposta dal sistema. Il flusso che integra l'MFA si compone, dal punto di vista dell'applicazione che adotta il sistema APMS, dei seguenti passaggi:

1- Redirect verso l'endpoint APMS-MFA

Prima di innescare il flusso di autenticazione ordinario e in assenza quindi di un utente già attivo nell'area riservata, l'applicazione effettua una redirect verso l'endpoint <https://portaleprofilazioni-mfa.azero.veneto.it> aggiungendo in *query-string* i parametri *applicazione*, contenente come valore il codice applicazione registrato su APMS, *idSessione*, contenente come valore un identificativo univoco della sessione di login, generato dall'applicazione, in formato UUID e *clientId*, contenente come valore l'identificativo del client di login come registrato su APMS.

	Specifiche di integrazione autenticazione APMS
---	---

Esempio:

<https://portaleprofilazioni-mfa.azero.veneto.it?applicazione=CODAPP&idSessione=93306728-0449-4144-885b-98b1ba7648aa&clientId=3d7cf0fams4tegv1o3lrbaop6>

Nota: per l'ambiente di test l'endpoint di riferimento è <https://portaleprofilazioni-mfa-test.azero.veneto.it>

2- Ricezione della *callback* da parte di APMS-MFA

APMS-MFA richiama l'applicazione in corrispondenza della url censita nel sistema APMS, aggiungendo in *query-string* i parametri *idSessione*, contenente il riferimento alla sessione di login corrente, e *codiceVerifica*, il cui valore è costituito da una stringa alfanumerica di sei caratteri.

Esempio:

<https://applicazione.azero.veneto.it?idSessione=93306728-0449-4144-885b-98b1ba7648aa&codiceVerifica=a89fgh>

3- Verifica della *callback* e attivazione del flusso di autenticazione ordinario

L'applicazione, verificata la corrispondenza dell'*idSessione*, esegue una chiamata REST POST verso l'API messa a disposizione dal sistema APMS in corrispondenza dell'endpoint <http://api-apms.apilink-prd.azero.veneto.it/api/v2/mfa/codiceVerifica> impostando nel *body* della *request* i parametri *idSessione* e *codiceVerifica* contente come valore quello ricevuto nella *callback*. A fronte di una risposta positiva (HTTP 200 OK) l'applicazione innesca il flusso di autenticazione ordinario che si conclude con la generazione dell'*ID_Token*. In tutti i casi di risposta negativa, l'applicazione nega l'accesso all'utente.

Nota: per l'ambiente di test l'endpoint di riferimento è <http://api-apms.apilink-test.azero.veneto.it/api/v2/mfa/codiceVerifica>

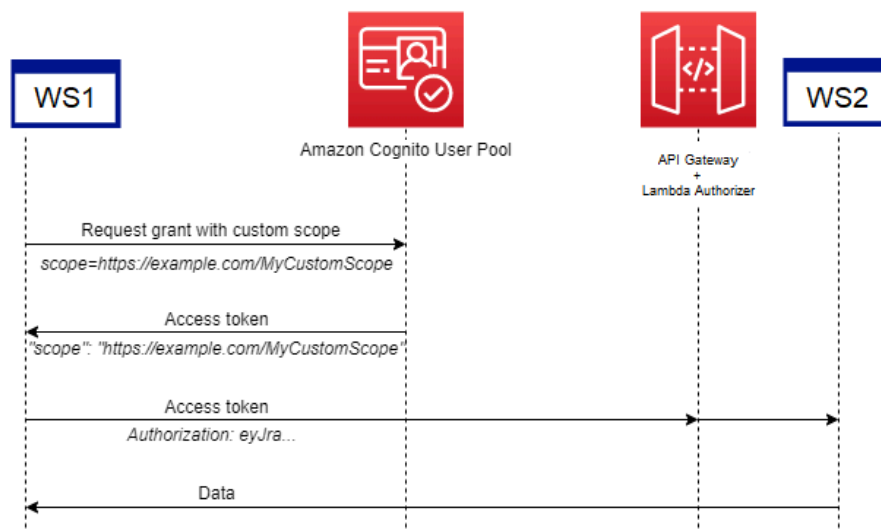
7 INTEGRAZIONE AUTENTICAZIONE MACHINE TO MACHINE (M2M)

Il sistema APMS consente anche la gestione di scenari in cui gli attori coinvolti nel flusso di autenticazione non siano gli utenti dei client applicativi ma servizi che hanno la necessità di effettuare chiamate protette verso altri servizi.

7.1 Scenario di autenticazione M2M

Lo scenario di autenticazione M2M al quale si farà riferimento nella descrizione del flusso di autenticazione è il seguente: il servizio A deve effettuare chiamate protette verso il servizio B.

7.2 Flusso di autenticazione



- 1- Il servizio A contatta l'opportuno endpoint di AWS Cognito, corrispondente al bacino di utenti sul quale il servizio A è stato censito come app client, richiamando il metodo POST /token, impostando, tra i diversi parametri previsti, *grant_type* con il valore *client_credentials* e *scope* con valori adeguati alle risorse del servizio B cui il servizio A



necessita di accedere e alle relative azioni da compiere. A titolo di esempio si considerino i possibili valori LETTURA e SCRITTURA per lo scope richiesto. La chiamata al servizio B sarà preceduta da un controllo di validità del token utilizzato (si veda punto 4) che impedirà di compiere azioni dispositive e/o di scrittura o modifica dei dati in presenza del solo scope LETTURA. I dettagli della chiamata al metodo /token sono esposti all'indirizzo

<https://docs.aws.amazon.com/cognito/latest/developerguide/token-endpoint.html>

- 2- AWS Cognito restituisce al servizio A un *access token*. Per i dettagli a riguardo si veda la documentazione all'indirizzo

<https://docs.aws.amazon.com/cognito/latest/developerguide/amazon-cognito-user-pools-using-the-access-token.html>

- 3- Il servizio A effettua la chiamata al servizio B (esposto tramite API Gateway) impostando come header *Authorization* l'*access token*.

- 4- L'API Gateway (tramite *lambda authorizer*) verifica la correttezza e la validità del token e delle informazioni in esso contenute secondo le prescrizioni descritte all'indirizzo <https://docs.aws.amazon.com/cognito/latest/developerguide/amazon-cognito-user-pools-using-tokens-verifying-a-jwt.html> e le modalità esposte all'indirizzo

<https://docs.aws.amazon.com/apigateway/latest/developerguide/apigateway-integrate-with-cognito.html>

- 5- Se le verifiche di cui al punto precedente hanno dato esito positivo, la chiamata viene instradata verso il servizio B dal quale, infine, il servizio A riceve risposta.